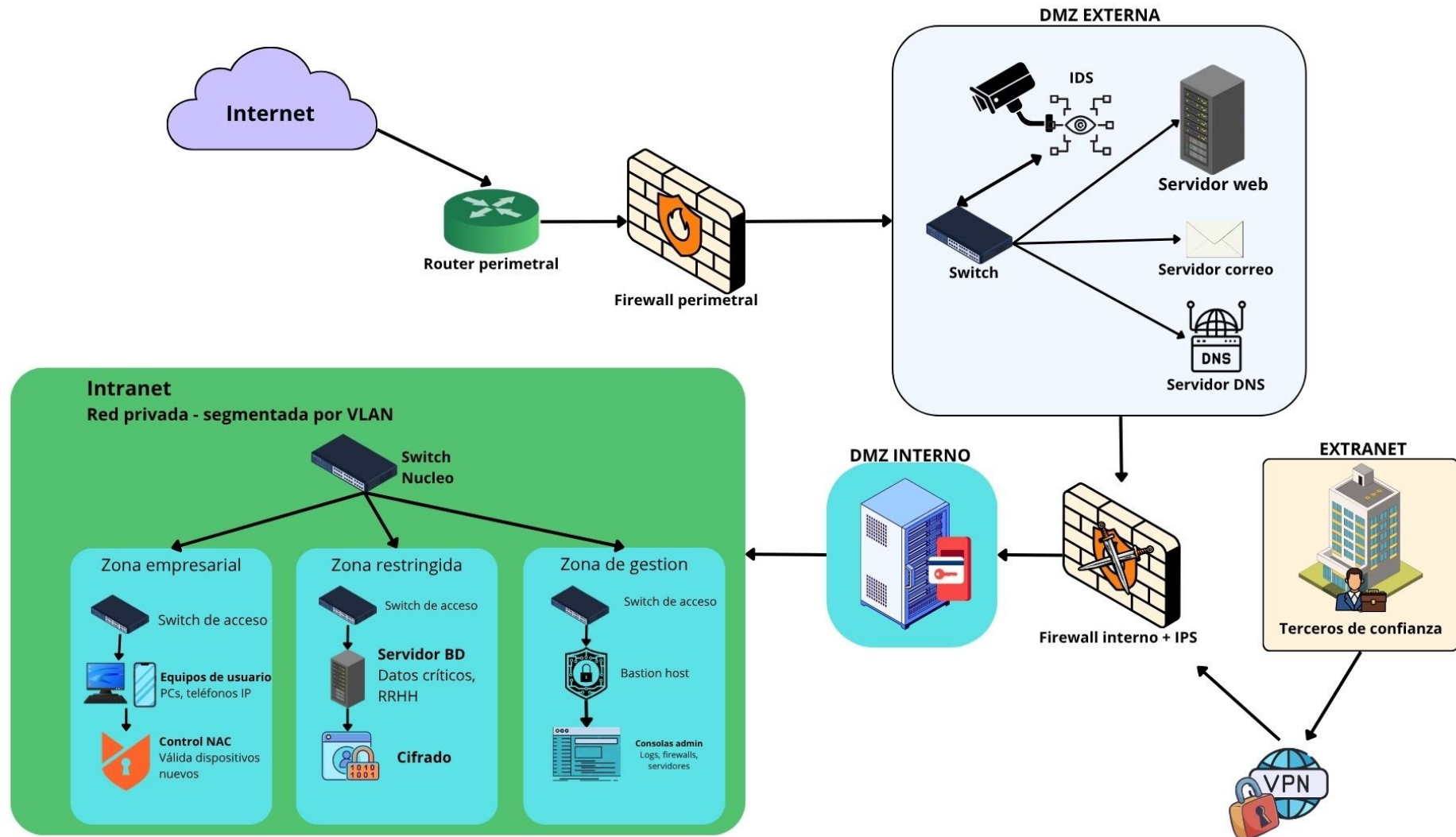


QUIZ 1 – CORTE 1

Integrantes: Kevin García
Andrés Castro
Julian Rincón

TOPOLOGIA



Empezamos con el router y el firewall perimetral como primer filtro: el router solo enruta, y el firewall decide qué puertos entran (80, 443, 25).

Los servicios públicos (web, correo, DNS) los aislamos en una DMZ externa para que, si comprometen uno, quede contenido ahí el switch de esa zona no tiene ruta hacia la intranet. Ahí mismo pusimos un IDS pasivo para detectar intentos de ataque sin afectar el tráfico real.

Agregamos un segundo firewall con IPS, más estricto que el perimetral, que solo deja pasar tráfico específico hacia la DMZ interna y bloquea en línea los patrones de ataque conocidos.

La DMZ interna la pusimos como intermediaria obligatoria: ningún servidor público toca la base de datos directamente, sino que pasa por un servidor de aplicaciones controlado.

A los terceros los hicimos entrar por una Extranet con VPN y autenticación fuerte, enrutada hacia la DMZ interna y nunca directo a la zona restringida los tratamos con el mismo nivel de desconfianza que al tráfico externo porque sus sistemas también pueden estar comprometidos.

Por qué dividimos la Intranet en estas tres zonas específicas:

Zona empresarial: Aquí están los equipos de los usuarios: PCs, teléfonos IP. La separamos porque es la zona con más gente y, por lo tanto, el vector de entrada más común: un solo clic en un phishing puede infectar una máquina. Le pusimos control NAC para que ningún dispositivo nuevo se conecte sin validarse primero, y la aislamos en su propia VLAN para que un equipo infectado no tenga visibilidad de las bases de datos ni de las consolas administrativas.

Zona restringida: Aquí viven los datos que realmente nos importan: bases de datos, información de RRHH, propiedad intelectual. Es el activo más valioso de la empresa, así que le dimos las medidas más estrictas: acceso solo con autenticación fuerte desde equipos autorizados, y cifrado tanto en reposo como en tránsito. La separamos de la zona empresarial precisamente para que un usuario comprometido no tenga camino directo hasta aquí.

Zona de gestión: Aquí están las herramientas de administración: consolas de firewalls, servidores, registros de seguridad. La tratamos como la más crítica de las tres porque quien tiene acceso aquí tiene permisos sobre toda la infraestructura comprometerla equivale a comprometer toda la red. Por eso obligamos a que todo acceso pase por un bastión host con MFA: en vez de dejar el acceso administrativo disperso entre varios equipos, lo concentramos en un solo punto auditable, con cada acción registrada.

Cada zona tiene su propio switch para que el compromiso de una no se propague automáticamente a las otras dos es la misma lógica de contención que usamos en toda la red, solo que aplicada dentro de la intranet.

Comando IPTables:

```
iptables -A OUTPUT -d 142.250.0.0/15 -m time --timestart 00:12 --timestop 00:13 -j DROP
```